

SSRF in Langchain Web Research Retriever in [langchain-ai/langchain](#)

✓ Valid

Reported on Mar 11th 2024

Description

The Web Research Retriever does not limit requests to the remote internet, it is possible to reach local addresses. This results in an SSRF vulnerability which can execute port scans, access local services, and in some cases even read instance metadata. As you requested in my other report, I made a separate report for this.

Proof of Concept

Step 1: Launch the langchain Web Explorer <https://github.com/langchain-ai/web-explorer/> (which implements a user interface for the Web Research Retriever) Step 2: Edit an attacker-owned google-indexed website with a code like this:

```
<?php
// Check for the real IP if behind Cloudflare
$realIP = $_SERVER['HTTP_CF_CONNECTING_IP'] ?? $_SERVER['REMOTE_ADDR'];

if ($realIP === 'victim_ip') {
    // Redirect to the specified URL
    header('Location: http://localhost:4321/real');
    exit; // Ensure no further execution in case of redirect
}
?>
```

The example code is written for an attacker website that is behind Cloudflare. If the victim IP is not known, one can also use a range allowlist / denylist instead. The IP check is only there to prevent Google and other search engines from de-indexing the site (the Googlebot should not be redirected).

Step 3: Send a query in the Web Explorer that will run a search which returns the attacker website in the search results. What the exact query is depends on the content of your specific site. I tried that briefly with a modified subsite of my own website to confirm the vulnerability (using my hardcoded IP), but took that change offline quickly for obvious reasons. The WebResearchRetriever will open all the websites of the first few search results, and it will follow redirects, also our redirect to the local IP address. This is the SSRF vulnerability. We can also

direct the Web Explorer in our LLM query to print back the response content of the websites, allowing us to read response data from local services.

Solution

I suggest to give the user an easy way to make the retriever use a proxy, and provide a quick guide how to do that securely so that it is segregated from the rest of the environment. For example in a cloud environment, one would create a new instance for the proxy only that cannot send any requests to the other instances and only has the proxy ports open.

CVSS explanation

This SSRF vulnerability makes it possible to scan ports, abuse the Web Explorer server as a proxy for attacks on third parties and interact with servers in the local network including reading their response data, which may allow to extract instance metadata if in a cloud environment. The attack consequences of interacting with local services depends heavily on the nature of these services. Regularly admin-privileged services are exposed locally on servers, so the consequences can go all the way up to arbitrary code execution. Sending POST requests is not possible, only GET, but integrity may still be affected as a result of stolen credentials or because especially on internal APIs also GET requests can be state-changing. For all these reasons, I chose to set Confidentiality, Integrity, Availability metrics to H, L, L, the result is not an uncommon score for SSRF vulnerabilities. See also the reference. (Unfortunately, I could not find many references for CVSS scoring SSRF vulnerabilities, and CVSS scores can vary wildly. But this one allows reading response data like instance metadata and accessing arbitrary URLs, so I set the metrics as explained)

Impact

SSRF allows port scans in the local network and abusing the server as proxy for web attacks on third parties. If the Web Research Retriever is running in a server environment together with other API servers, the vulnerability allows interacting with these services and reading response data. If the web explorer is running in a cloud environment, it becomes possible to read instance metadata from the metadata endpoints. The only restriction is that we cannot set custom headers, but there are still providers where this is not required (Google Beta endpoint, DigitalOcean, see reference).

Occurrences

 `async_html.py` L83

References

- [SSRF consequences in the cloud](#)
- [CWE-918: Server-Side Request Forgery \(SSRF\)](#)

- [SSRF CVSS reasoning](#)

⚙️ We are processing your report and will contact the [langchain-ai/langchain](#) team within 24 hours. 2 years ago

✉️ We have contacted a member of the [langchain-ai/langchain](#) team and are waiting to hear back 2 years ago



✎️ **Dan McInerney** modified the Severity from High (7.7) to Medium (6.3) 2 years ago

✉️ We have sent a follow up to the [langchain-ai/langchain](#) team. We will try again in 4 days. 2 years ago



👁️ A [langchain-ai/langchain](#) maintainer has acknowledged this report 2 years ago

✎️ The scheduled publication date was automatically extended from 26th Apr 2024 to 3rd May 2024 due to the maintainers acknowledgement of the report 2 years ago



Eugene Yurtsev commented 2 years ago

Maintainer

We'll review in a bit. I'm not convinced that a network attack is the correct way of classifying this. The web research retriever is NOT a server by default.



Elias Hohl commented 2 years ago

Researcher

I classified it as network because the actual payload is delivered over a website, which can be an attacker controlled website. Server access to the victim is not required, it is just necessary that the victim somehow gets such a website displayed in the search results (which can also happen by coincidence).

If you disagree you can also downgrade to Local



✎️ **Eugene Yurtsev** modified the Severity from Medium (6.3) to Medium (4.8) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✅ **Eugene Yurtsev** validated this vulnerability 2 years ago

\$ **ehtec** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2024-3095 assigned to this report. 2 years ago



Eugene Yurtsev commented 2 years ago

Maintainer

I looked at the underlying implementation -- an attack seems very difficult to execute in a meaningful way -- even a medium score here sounds too high.



Elias Hohl commented 2 years ago

Researcher

Don't understand how you mean that, I successfully executed such SSRF attack for testing, it is not just a theoretical concept.



Eugene Yurtsev commented 2 years ago

Maintainer

Ahh i missed the redirect

⚠ We have sent a warning to the **langchain-ai/langchain** team to inform them that this report will be published in 48 hours 2 years ago



This vulnerability has now been published 2 years ago



CVE-2024-3095 has now been published 2 years ago



Eugene Yurtsev commented 2 years ago

Maintainer

We should've fixed up the report to link to the actual code. It's right now linking to the AsyncHTML loader instead of to the WebRetriever.



Eugene Yurtsev marked this as fixed in **0.2.9** with commit **604dfe** 2 years ago

\$ The fix bounty has been dropped ✖

\$ `async_html.py#L83` has been validated ✔



Eugene Yurtsev commented 2 years ago

Maintainer

The fix and the issue are both in the langchain-community package NOT the langchain package

[Sign in](#) to join this conversation

Vulnerability Type

CWE-918: Server-Side Request Forgery (SSRF)

Severity

Medium (4.8)

Attack vector	Physical
Attack complexity	High
Privileges required	Low
User interaction	None
Scope	Changed
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Other

Affected Version

0.1.5

Visibility

Public

Status

Fixed

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



Elias Hohl

@ehtec

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

